

Obligatory Exercise 2

Answers to readme questions:

1. I admit it, the task was easy enough. If it were a flash drive that I had to get from a commander I would first, try to get more information about him which could aid me in the future. Getting in touch with him through video games (if he plays any) or social media (somehow) would be nice. Getting to know his family members too.

Now, phishing is a low-risk option and easy to realize. I can try to deepfake one of his relatives or vice versa to expose some sensitive information as long as there is enough footage for deepfake to learn from. Maybe even trick him into installing spyware on some critical device. Since we don't need the flash drive itself, but the information inside, we shouldn't try stealing it physically since he would notice, simply copy-pasting info inside is enough. There is probably more I could do though.

Something unnecessarily riskier would be to meet him in some public place where I can try and temper with his devices without him noticing or hope that he just so happens to have the important flash drive with him in public, that would be convenient... Of course we can do the thing from the movies, become a guard and sneak in, but it will never work and is too complicated to begin with.

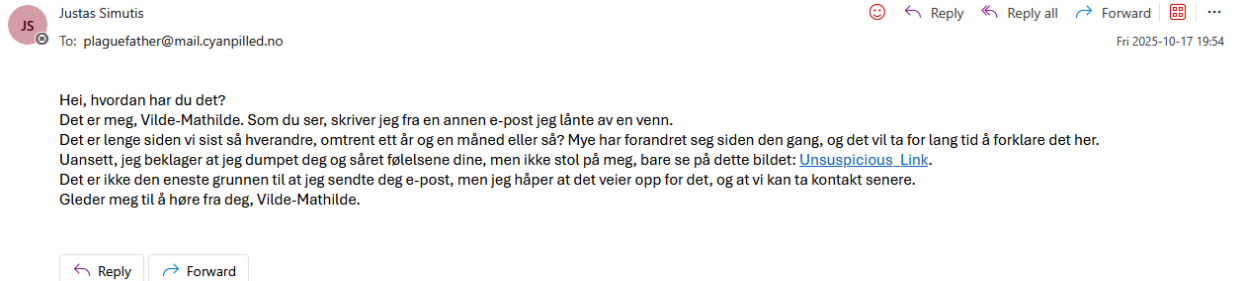
2. Yes, I understood what it does. Three Things based on arguments. If there are no arguments it outputs "Hei Verden!". If the argument is "exec", then it plays a little guessing game plus some story. If the first argument is "xor", second is some text, and third is a number, then the result is that it applies the input number of XOR iterations on the input text.
3. What message? If you mean the "Mainframe is now ours" and so on, then yes. If it is the second rick roll (phase 1.5), then yes. If it is the link to phase 2, also yes.
4. The file types are not correct. These aren't .jpeg files and were simply assigned to be ones even though they are useless in this form. Also, as I understand it, these files are simply copies of each other and are meant to be executed. Though when comparing those files as .txt, the order of some things changes for some reason.

5. I mean... since the only thing we can do is to submit our input, I can try to do XSS attack to inject my own code for whatever reason. MiTM (Man in The Middle) is unlikely since that requires me to alter root's database where all the public keys are stored, not sure how SQL Injection works in those cases, never done that before.
6. What I did is simply type "admin'; --" into as username, and "1" as password. Since everything is commented out, what the SELECT * command searches for is the row where the username is "admin".

ID	Username	Password (Hashed)	Role
1	admin	790b52e4929 ...	admin
3	Phix	b8c209cdead ...	user
4	Mamaboi87	790b52e4929 ...	user
9	TenderTitan	3b399939ff72...	user
10	PunyMarius	39da97c3173 ...	user
16	MAPSboi2	5c52b6deb36...	user
23	IApologise	8d969eef6ec ...	user

7. I used John The Ripper like "john hashes.txt --wordlist=rockyou.txt --rules=All --format=Raw-SHA256 --fork=32" and quickly found admin's password. Apparently, the admin and the user mamaboi87 have the same password since the hash is the same (and it is not salted and thus not peppered too).
8. The "--rules" command allows words from the wordlist to be tampered with and create their variants to have more options for testing. For example, a word like "123456" with "--rules" enabled will create variants such as "1234S6", "!23456", etc. Own rules can be created and specific ones used, not just "--rules=All" like I did.

9. The form for phishing that I did is called spear-phishing which is when we target someone in particular. I haven't made the actual phishing link and a separate email (added an excuse instead because I was too lazy for that which is bad since I am exposing myself if I get caught). Anyways, here is the proof below.



There are also other types of phishing such as mass-phishing and whale-phishing. Mass-phishing is when you are trying to phish lots of people at once, usually by spamming general emails which very few people get tricked by. Sometimes methods are more sophisticated than that. Whale-phishing is when you try to phish someone important such as a CEO. Those usually don't have much time so they comply with the requests without looking much into it and issue orders directly to those below without them questioning their authority. They are also more valuable to phish overall if one wants to gain money or status, etc.

10. It is illegal to steal stuff such as people's flash-drives and be where I am not supposed to be. It is also illegal to spy on someone or get into other people's diaries since that goes directly against one's confidentiality. Hacking into admin's account is also illegal since that gives power to unauthorized users which already breaks reliability and might also break integrity, traceability, and accessibility depending on one's actions. It is legal to create my own account on the website though :)